

NorthBridge Technology Solutions Inc.

Information Security Management System

Access Control Policy

POL-003

DOCUMENT CONTROL	
Policy Title	Access Control Policy
Policy ID	POL-003
Version	1.0
Date	05/16/2026
Author	Ashkon Irani
Reviewed By	IT Director
Approved By	Chief Executive Officer
Classification	Confidential
Applies To	All employees, contractors, and third-party personnel with access to NorthBridge systems
Review Frequency	Annual, or following any significant change to the identity and access management environment
Related Documents	POL-001, POL-002, POL-004, NB-ISMS-002, NB-ISMS-004 (RSK-002, RSK-005, RSK-011)
ISO 27001 Controls	5.15, 5.16, 5.17, 5.18, 8.2, 8.3, 8.5

1. Purpose

This Access Control Policy defines the requirements governing how access to NorthBridge Technology Solutions Inc. information systems, applications, networks, and data is granted, managed, reviewed, and revoked. Access control is one of the most critical security functions in any organization. Every unauthorized access event -- whether caused by an external attacker, a malicious insider, or a well-intentioned employee for accessing systems beyond their role -- represents a failure of access control.

For NorthBridge, the stakes of access control failure are particularly high. As a federal IT contractor, NorthBridge processes Government of Canada Protected B information on behalf of its clients. Unauthorized access to this information would constitute a federal security incident, trigger mandatory client notification, and may result in contract termination and regulatory investigation. This policy establishes the controls required to ensure that access to NorthBridge and client systems is always authorized, appropriate, and accountable.

This policy directly addresses risks of RSK-002 (unauthorized access to Protected B data), RSK-005 (credential compromise via phishing), and RSK-011 (privileged account compromise) as documented in the NorthBridge Risk Register (NB-ISMS-004).

2. Scope

This policy applies to:

- All NorthBridge employees, contractors, consultants, and third-party personnel who have been granted access to any NorthBridge system, application, or data asset
- All information systems, applications, cloud environments, and networks within the ISMS scope as defined in NB-ISMS-001, including Microsoft Azure, Microsoft 365, Azure DevOps, ServiceNow, and the NorthBridge VPN infrastructure
- All user accounts including standard user accounts, administrator accounts, service accounts, and shared accounts
- All access methods including physical presence, remote access via VPN, cloud-based access, and API-based system-to-system access

3. Access Control Principles

All access control decisions at NorthBridge are governed by the following core principles. These principles take precedence over convenience, speed, or individual preference in every situation.

Principle	Application at NorthBridge
Least Privilege	Every user, system, and process is granted only the minimum level of access required to perform their assigned function. Access is never granted more than current business needs. When in doubt, grant less access and expand upon demonstrated need.
Need to Know	Access to specific information assets is granted only to individuals who have a documented business requirement to access that information. Job title alone does not constitute a need to know. Access to GoC client data is limited to staff directly assigned to the relevant client engagement.
Separation of Duties	No individual should have sufficient access to both initiate and approve a security-sensitive transaction without oversight. This applies particularly to code deployment to production, financial transactions, and user account provisioning. Where full separation is not operationally feasible, compensating controls such as audit logging and dual approval are implemented.
Accountability	Every access event must be traceable to a specific individual. Shared accounts that cannot be attributed to a single user are prohibited except in explicitly authorized circumstances. All privileged access sessions are logged with sufficient detail to reconstruct actions taken.

Default Deny	Access is denied by default. Users receive no access to any system unless it has been explicitly granted through the provisioning process defined in this policy. New systems are configured with all access disabled until access requirements are formally defined and approved.
---------------------	--

4. User Account Management

4.1 Account Types

NorthBridge maintains the following account types. Each type carries different access privileges and security requirements.

Account Type	Description	Key Security Requirements
Standard User Account	Assigned to all employees and contractors for day-to-day business activities. Access limited resources required for the individual's role.	MFA enforced. Password complexity policy applied. Access reviewed quarterly.
Privileged Administrator Account	Assigned to IT staff requiring administrative access to manage systems, configure security controls, or access all data. Separate from a standard user account.	MFA enforced with hardware token or FIDO2 key. Used only for administrative tasks. Session recording enabled. Access reviewed monthly.
Service Account	Non-human accounts are used by applications and automated processes to interact with other systems. Not assigned to individuals.	No interactive login is permitted. Passwords rotate automatically. Access is limited to specific APIs and services only. Reviewed quarterly.
Shared Account	Accounts shared between multiple users. Strongly discouraged and only permitted where individual accounts are technically impossible.	Requires written approval from the IT Director. All users of the shared account are documented. Enhanced logging applied. Reviewed monthly.
Temporary Account	Short-duration accounts created for contractors, project staff, or third parties with a defined engagement end date.	Expiry date set at creation. Access automatically revoked on expiry date. Cannot be extended without formal re-approval from the IT Director.

4.2 Account Provisioning (Joiner Process)

New accounts are created only upon receipt of a formally approved access request. The following process applies to all new account creations regardless of account type.

Step	Action	Responsibility and Detail
1	Access request submitted	The new user line manager submits a formal access request via ServiceNow at least 3 business days before the user's start date. The request must specify the exact systems, applications, and data the user requires access to, with a business justification for each.
2	Request reviewed and approved	The IT Director or delegated IT Manager reviews the request against the user's role. Access is approved only for systems with documented business justification. Requests for access to GoC

		client environments require additional approval from the relevant Client Engagement Manager.
3	Account created	The IT team creates the account in Azure Active Directory with only the approved access granted. No additional access is added beyond what was explicitly approved. MFA enrollment is configured and required before first login.
4	Credentials delivered securely	Initial login credentials are delivered to the user via a secure out-of-band channel. Temporary passwords are set to expire on first use, requiring the user to set up a new password meeting the complexity requirements in Section 5.
5	Access confirmed	The IT team confirms that the new account has access to the approved systems only, and that no additional permissions have been granted. The account is added to the access rights register.

4.3 Access Modification (Mover Process)

When an employee changes roles, department, or engagement, their access rights must be updated to reflect their new responsibilities. The following requirements apply:

- The line manager must notify the IT team of the role change at least 2 business days before it takes effect
- All access rights associated with the previous role that are not required in the new role must be revoked on the effective date of the role change
- New access required for the new role must be formally requested and approved through the provisioning process in Section 4.2
- Under no circumstances should a user accumulate access from both their old and new roles. Privilege accumulation is a significant security risk and a common audit finding
- The IT Director must be notified of any role change that involves gaining or losing access to GoC client environments

4.4 Account Deprovisioning (Leaver Process)

The timely revocation of access when an individual leaves NorthBridge or has their engagement terminated is one of the most critical access control activities. Delays in revoking access create a significant window of risk, particularly where the departure is involuntary.

Departure Type	Required Action	Timeframe
Voluntary resignation with notice period	All access was revoked on the last day of employment. HR notifies the IT team at least 5 business days before the final date. Device returned and wiped on the final day.	All access revoked by end of business on the final working day.
Involuntary termination	All access is revoked immediately at the time the individual is notified of termination. The IT team placed on standby before the termination meeting occurs. Devices are collected immediately.	All access revoked within 1 hour of notification of termination.

Contractor or third-party engagement end	All access revoked on the contract end date. Temporary accounts are set to expire automatically at creation. Client engagement manager confirms all access removed.	Access revoked on or before the contract end date. Automatic expiry as primary control.
Employee suspended pending investigation	All system access suspended immediately pending outcomes of investigation. Physical access to facilities reviewed by Operations Manager.	All access suspended within 2 hours of suspension decision.

The IT Director is responsible for maintaining an offboarding checklist that confirms revocation of all access including Azure Active Directory account, Microsoft 365 license, VPN certificates, Azure DevOps repository access, ServiceNow access, physical keycard access, and any client-specific system access. The completed checklist must be signed by the IT Director and retained for a minimum of 12 months.

5. Authentication Requirements

5.1 Password Standards

All passwords protecting NorthBridge accounts must meet the following minimum requirements. These requirements are enforced technically via Azure Active Directory password policies where possible and through user awareness where technical enforcement is not available.

Requirement	Standard User Accounts	Privileged Administrator Accounts
Minimum length	14 characters	20 characters
Complexity requirements	Must include uppercase, lowercase, numbers, and special characters	Must include uppercase, lowercase, numbers, and special characters
Maximum age	365 days	90 days
Password history	Last 12 passwords cannot be reused	Last 24 passwords cannot be reused
Account lockout	Account locked after 10 failed attempts, unlocked after 30 minutes or by IT team	Account locked after 5 failed attempts, requires IT Director to unlock manually
Password manager	Use of an approved password manager is strongly recommended	Use of the NorthBridge corporate password manager (1Password Teams) is mandatory

Passwords must never be shared with any other individual for any reason, including colleagues, IT staff, or managers. The IT team will never ask a user for their password. Any request for a password from any source must be treated as a potential social engineering attack and reported to the IT Director immediately.

5.2 Multi-Factor Authentication

Multi-factor authentication is mandatory for all NorthBridge accounts accessing any system within the ISMS scope. MFA adds a second layer of verification beyond the password, ensuring that a compromised password alone is not sufficient for an attacker to gain access.

The following MFA requirements apply:

Access Scenario	Required MFA Method	Notes
All Microsoft 365 access	Microsoft Authenticator app push notification or TOTP code	Enforced via Conditional Access policy. Legacy authentication protocols are blocked organization wide.
VPN access	Certificate-based authentication plus Authenticator app	VPN connection is rejected if MFA is not completed. Certificate issued by NorthBridge PKI infrastructure.
Azure portal and administrative access	FIDO2 hardware security key (e.g., YubiKey) as primary method	Phishing-resistant MFA required for all administrative access. Authenticator app not accepted for admin accounts.
Azure DevOps and source code repositories	Microsoft Authenticator app push notification	MFA enforced for all interactive logins. Service accounts use certificate-based authentication only.
GoC client environment access	As specified by client security requirements, minimum Microsoft Authenticator app	Client-specific MFA requirements take precedence. IT Director must confirm MFA method meets client security baseline.

MFA bypass requests are not accepted. If a user is unable to complete MFA due to a lost or damaged authentication device, they must contact the IT team during business hours to verify their identity through the identity verification procedure and have their MFA method reset. There is no self-service MFA bypass.

5.3 Session Management

The following session management controls apply to all NorthBridge systems:

- Screen lock must activate automatically after a maximum of 10 minutes of inactivity on all NorthBridge devices
- Users must lock their screen manually whenever they leave their workstation unattended, regardless of duration
- Remote sessions to internal systems must time out after 60 minutes of inactivity
- Browser sessions to cloud applications must require re-authentication after 8 hours
- Concurrent sessions from multiple geographic locations or devices for the same account will trigger an alert to the IT security team

6. Privileged Access Management

Privileged access accounts represent the highest risk in NorthBridge's access control environment. A compromised administrator account gives an attacker the ability to access all systems, modify or

delete all data, create new accounts, and cover their tracks by altering logs. This section defines the enhanced controls that apply specifically to privileged access.

6.1 Privileged Access Principles

- All IT staff with administrative responsibilities must maintain two separate accounts: a standard user account for daily productivity tasks such as email and document creation, and a dedicated administrator account used exclusively for administrative activities
- Administrative accounts must never be used for email, web browsing, or any activity other than the specific administrative task for which they are intended
- Administrative tasks must be performed on a Privileged Access Workstation (PAW) that is hardened, restricted from general internet access, and used exclusively for administrative functions
- Just-in-time access must be implemented for administrative access to production environments that are technically feasible. Access is elevated for the duration of the task only and automatically revoked upon completion
- All privileged sessions must be recorded. Session recordings are retained for a minimum of 90 days and are available for review by the IT Director at any time

6.2 Privileged Account Inventory

The IT Director maintains a privileged account inventory documenting all accounts with administrative, root, or elevated permissions across all NorthBridge systems. This inventory is reviewed monthly and includes:

- The account name and system it belongs to
- The individual or system the account is assigned to
- The specific administrative permissions granted
- The business justification for the elevated access
- The date of last review and next scheduled review

Any account not listed in the privileged account inventory that is discovered to have elevated permissions is treated as a potential security incident and investigated accordingly.

6.3 Emergency Access

Emergency break-glass accounts are maintained for scenarios where all normal administrative access is unavailable, such as during a ransomware incident where domain controllers have been compromised. The following controls govern emergency access:

- Break-glass credentials are stored in a sealed envelope in the physical safe at the Ottawa HQ server room
- Access to the sealed envelope requires written authorization from the CEO or IT Director
- Any use of break-glass credentials must be logged immediately in the incident record and reviewed by the IT Director within 24 hours
- Break-glass credentials are rotated immediately following any use and at least every 6 months regardless of use

7. Remote Access

Remote access to NorthBridge internal systems and GoC client environments is a significant attack surface that requires specific controls beyond standard access management.

7.1 VPN Requirements

All remote access to NorthBridge internal systems must be conducted exclusively via the NorthBridge Cisco AnyConnect VPN. The following requirements apply:

- Split tunneling is disabled. All traffic from remote devices is routed through the VPN and subject to NorthBridge security monitoring
- VPN access requires both certificate-based authentication and MFA as defined in Section 5.2
- VPN sessions are logged including source IP, connection time, duration, and volume of data transferred
- Anomalous VPN activity including connections from unexpected geographic locations, unusual connection times, or abnormally high data transfer volumes triggers an automatic alert to the IT security team
- Personal devices are not permitted to connect to the NorthBridge VPN unless a formal BYOD exception has been approved in accordance with POL-002

7.2 Third-Party Remote Access

Third-party vendors, contractors, and support personnel who require remote access to NorthBridge systems must be granted access through the standard provisioning process in Section 4.2. The following additional requirements apply:

- Third-party remote access must be time-limited and tied to a specific engagement or support activity
- Third parties must connect via a designated VPN profile with access restricted to only the systems required for their task
- All third-party remote sessions are logged and reviewed by the IT team
- Third-party access to GoC client environments requires explicit written approval from the relevant government client before being provisioned

8. Access Rights Review

Access rights accumulate over time as staff change roles, take on additional projects, and acquire temporary access that is never removed. Regular access rights reviews are essential to ensure that the principle of least privilege is maintained over time and that no individual retains access beyond their current business needs.

Review Type	Frequency	Scope	Owner
-------------	-----------	-------	-------

Standard user access review	Quarterly	All standard user accounts across Microsoft 365, Azure, and key business applications. Line managers confirm whether each team member's access remains appropriate.	IT Manager, with line manager confirmation
Privileged access review	Monthly	All privileged and administrator accounts across all systems. The IT Director personally reviews each account.	IT Director
GoC client environment access review	Monthly	All accounts with access to Government of Canada client environments. Client Engagement Manager confirms an active project assignment for each user.	IT Director and Client Engagement Manager
Service account review	Quarterly	All service accounts and system-to-system access credentials. Confirm each account is still required, and permissions remain appropriate.	IT Manager
Full recertification	Annual	Complete review of all accounts and access rights across all systems. Results were reported to the CEO at the annual ISMS management review.	IT Director

Where a review identifies access rights that are no longer required, those rights must be revoked within 5 business days of the review finding. The IT Director documents all revocations and retains this evidence for audit purposes. Failure to revoke access identified as unnecessary during a review is itself a policy violation.

9. Physical Access Control

Physical access to NorthBridge facilities, particularly in the server room, must be controlled with the same rigor as logical system access. Physical access to the server room is equivalent to administrative access to all on-premises network infrastructure.

- Physical access to the NorthBridge Ottawa HQ is controlled by keycard. Access is provisioned and revoked through the same joiner-mover-leaver process as logical system access
- Access to the server room on Floor 2 is restricted to IT team members only. A maximum of 4 individuals hold server room keycard access at any time

- All server room access events are logged by the physical access control system. The IT Manager reviews access logs monthly
- Visitors to the Ottawa HQ must sign in at reception and are always escorted while in the building
- No visitor may enter the server room under any circumstances without written approval from the IT Director and must be accompanied by a member of the IT team throughout their visit
- Physical access rights are revoked as part of the leaver process. Keycards must be returned on the final day of employment or engagement

10. Logging and Monitoring of Access

All significant access events across NorthBridge systems are logged to support security monitoring, incident investigation, and audit activities. Access logs are treated as security-sensitive information and protected from unauthorized modification.

10.1 Events That Must Be Logged

- All successful and failed login attempts to any NorthBridge system
- All MFA challenges and their outcomes (success or failure)
- All account creation, modification, and deletion events
- All access rights changes including role assignments and permission grants or revocations
- All privileged session activity
- All VPN connection and disconnection events
- All access to GoC client environments
- All access to systems classified as Restricted in the NorthBridge Asset Inventory

10.2 Log Retention

Access logs must be retained for a minimum of 12 months in accessible storage. Logs older than 12 months may be archived for cold storage and retained for a further 6 years to support potential legal proceedings or regulatory investigations. Log retention aligns with GoC contract requirements and PIPEDA obligations.

10.3 Alerting

The following access events generate automatic security alerts to the IT Director or IT security team:

- 5 or more consecutive failed login attempts on any account
- Successful login to a privileged account outside of normal working hours (defined as 07:00 to 19:00 Eastern Time on business days)
- Login from a geographic location inconsistent with the user's normal work pattern
- Concurrent active sessions for the same user account from different devices or IP addresses
- Any login attempt using credentials that have been flagged as potentially compromised via Microsoft Entra ID Protection or the NorthBridge password manager breach monitoring

11. Roles and Responsibilities

Role	Access Control Responsibilities
IT Director	Owns this policy and is accountable for its implementation. Approves all access to GoC client environments and all privileged account requests. Reviews privileged access monthly. Manages emergency access credentials. Sign off on all offboard access revocation checklists.
IT Manager	Executes account provisioning, modification, and deprovisioning processes. Maintains the access rights register. Conducts quarterly standard user access reviews. Reviews physical access control logs monthly. Manages VPN certificate issuance.
Line Managers	Submit access requests for new team members. Notify the IT team of role changes within 2 business days. Confirm appropriateness of team member access during quarterly reviews. Ensure departing team members return devices and acknowledge access revocation.
HR Department	Notifies the IT team of new hires at least 3 business days before the start date. Notifies the IT team of planned departures with as much notice as possible. Triggers immediate notification to the IT Director in cases of involuntary termination before the termination meeting occurs.
All Users	Always protect their credentials. Report any suspected credential compromise immediately. Never share passwords or MFA devices. Request access only for systems they have a legitimate business needs to use. Report any access they believe they hold more than their current needs.

12. Non-Compliance and Enforcement

Violations of this policy are treated as serious security events. The following consequences apply in addition to those set out in the Information Security Policy (POL-001):

- Sharing of passwords or MFA devices: Immediate suspension of access pending investigation. Mandatory security training. Formal written warning.
- Accessing systems beyond authorized role: Investigation to determine whether data was accessed inappropriately. Disciplinary action is proportionate to intent and impact. Potential termination.
- Failure to report a suspected credential compromise: Treated as negligent behavior. Disciplinary action and mandatory remedial training.
- IT staff failure to revoke access within defined timeframes: Formal written warning to the IT Manager. Escalation to the IT Director if a pattern of failures is identified.
- Any access control failure resulting in unauthorized access to Protected B GoC client data: Treated as a P1 security incident. All consequences in the POL-004 Incident Response Policy apply. Mandatory regulatory and client notifications.

13. Policy Review and Approval

This policy is reviewed annually by the IT Director and approved by the Chief Executive Officer. Reviews are also triggered by significant changes to the NorthBridge technology environment, identity and access management infrastructure, or GoC client security requirements.

Role	Name	Signature	Date
Author	Ashkon Irani	[Signed]	05/16/2026
Reviewer	IT Director	[Signed]	05/16/2026
Approver	Chief Executive Officer	[Signed]	05/16/2026

-- End of Document --

POL-003 v1.0 | NorthBridge Technology Solutions Inc. | CONFIDENTIAL